NAME: THULASI S **ROLL:NO: 241901118**

EXP 11: PERFORM CROSS-SITE REQUEST FORGERY (CSRF)ATTACK.

AIM:

To study and demonstrate a Cross-Site Request Forgery (CSRF) scenario in the intentionally vulnerable DVWA application by inspecting the password-change request at Low security using Burp Suite.

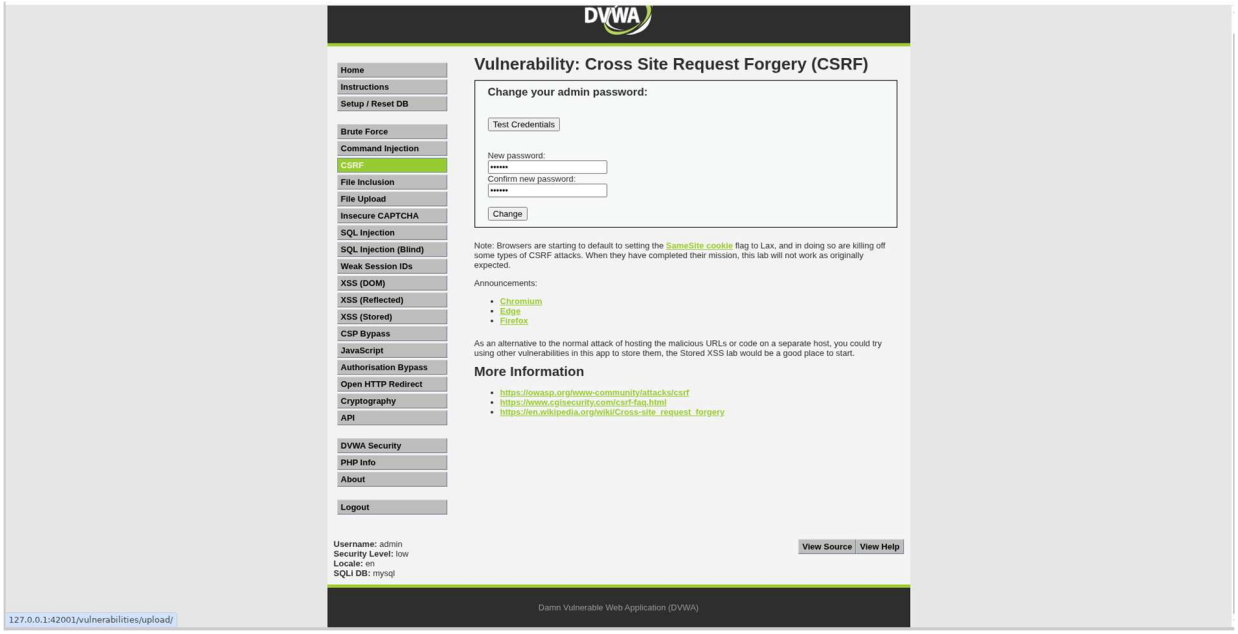
ALGORITHM:

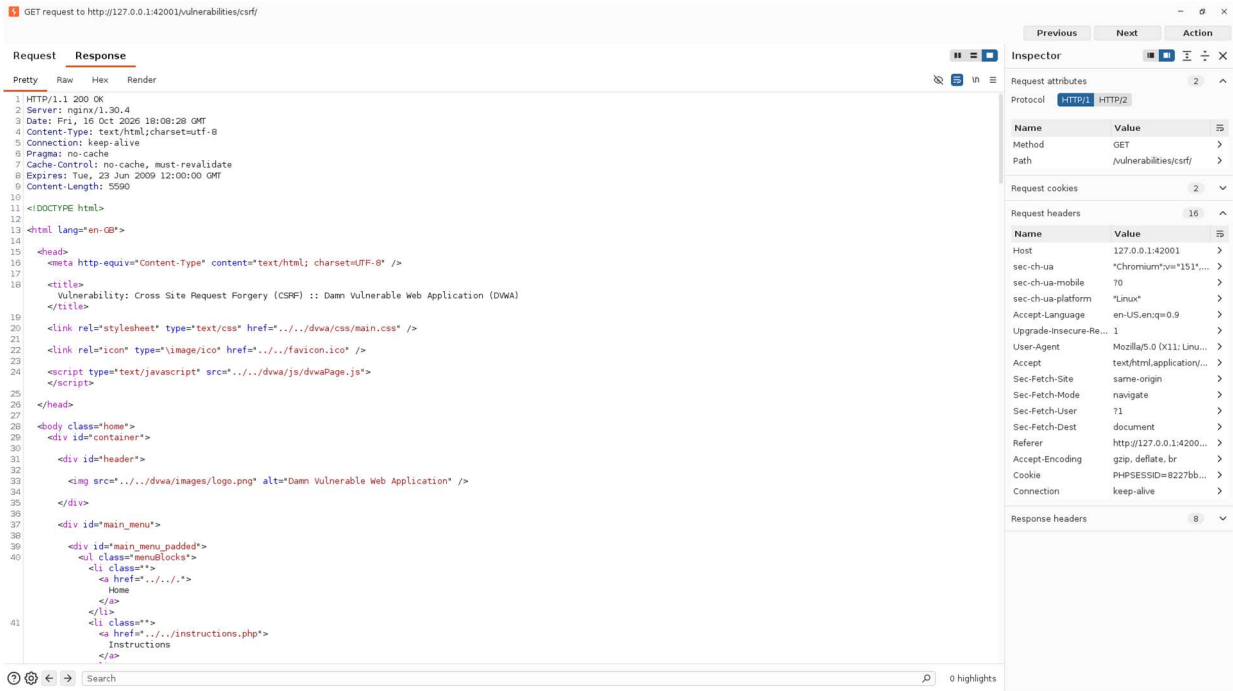
1. Start the DVWA service in Kali and open http://127.0.0.1:42001 in the browser.
2. Log in to DVWA and open DVWA Security. Set the security level to Low and save the setting.
3. Select Vulnerabilities → CSRF to display the password-change form.
4. Open Burp Suite and use Proxy → HTTP history to locate the request sent by the CSRF page.
5. Inspect the request parameters. The captured request contains password_new, password_conf, and Change=Change. The displayed request does not contain a user_token parameter.
6. Inspect the response. The supplied capture shows HTTP/1.1 200 OK and the DVWA CSRF page HTML. This response confirms that the page was returned, but by itself does not prove that the password was changed.
7. If required by the lab instructor, perform a controlled proof-of-concept only against this local DVWA instance, then verify the outcome using DVWA's Test Credentials control. Do not test against any real or third-party website.

TOOLS REQUIRED

- Kali Linux (WSL)
- Damn Vulnerable Web Application (DVWA)
- Burp Suite Community Edition
- Web browser
- Text editor and local HTTP server (for the optional proof-of-concept page)

OUTPUT:


DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
Authorisation Bypass
Open HTTP Redirect
Cryptography
API
DVWA Security
PHP Info
About
Logout
Vulnerability: Cross Site Request Forgery (CSRF)
Change your admin password:
Test Credentials
New password:
Confirm new password:
Change
Note: Browsers are starting to default to setting the SameSite cookie flag to Lax, and in doing so are killing off some types of CSRF attacks. When they have completed their mission, this lab will not work as originally expected.
Announcements:
Chromium
Edge
Firefox
As an alternative to the normal attack of hosting the malicious URLs or code on a separate host, you could try using other vulnerabilities in this app to store them, the Stored XSS lab would be a good place to start.
More Information
https://owasp.org/www-community/attacks/csrf
https://www.cgisecurity.com/csrf-faq.html
https://en.wikipedia.org/wiki/Cross-site_request_forgery
Username: admin
Security Level: low
Locale: en
SQLi DB: mysql
View Source
View Help
Damn Vulnerable Web Application (DVWA)
127.0.0.1:42001/vulnerabilities/upload/


GET request to http://127.0.0.1:42001/vulnerabilities/csrf/
Previous
Next
Action
Request
Response
Pretty
Raw
Hex
Render
HTTP/1.1 200 OK
Server: nginx/1.30.4
Date: Fri, 16 Oct 2026 18:08:28 GMT
Content-Type: text/html;charset=utf-8
Connection: keep-alive
Pragma: no-cache
Cache-Control: no-cache, must-revalidate
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Content-Length: 5590
<!DOCTYPE html>
<html lang="en-GB">
<head>
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
<title>
Vulnerability: Cross Site Request Forgery (CSRF) :: Damn Vulnerable Web Application (DVWA)
</title>
<link rel="stylesheet" type="text/css" href="../../dvwa/css/main.css" />
<link rel="icon" type="\image/ico" href="../../favicon.ico" />
<script type="text/javascript" src="../../dvwa/js/dvwaPage.js">
</script>
</head>
<body class="home">

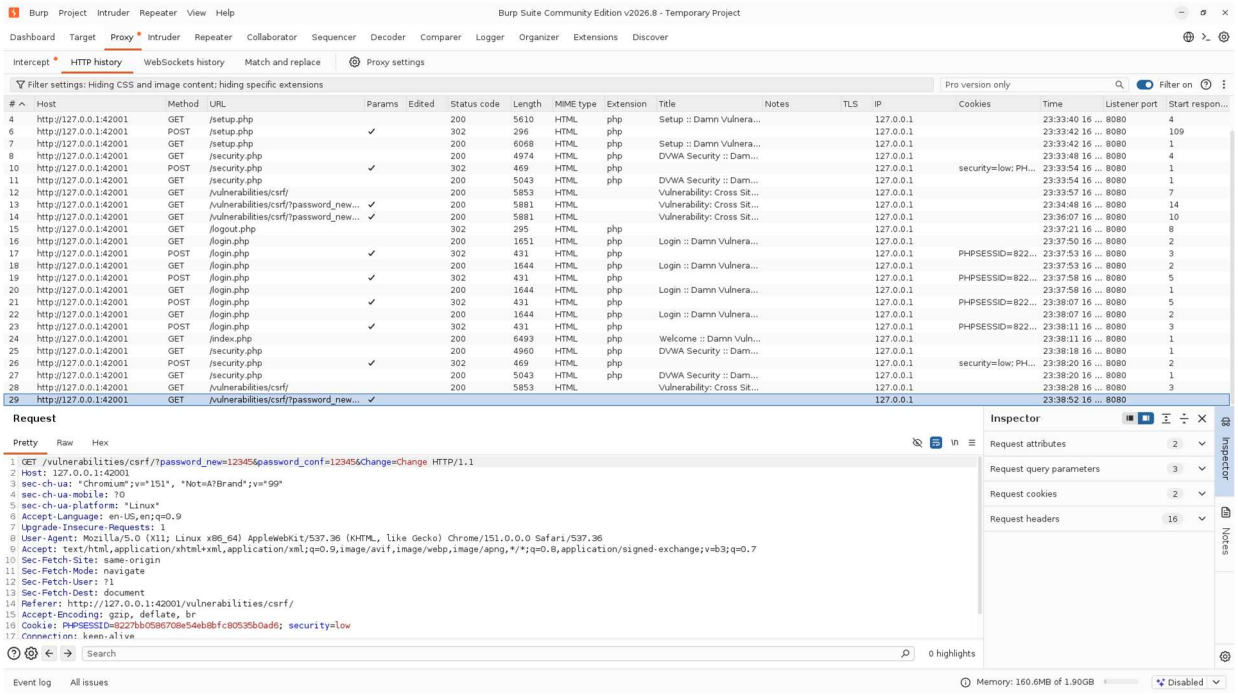
<ul class="menuBlocks">
<li class="">

Home

<li class="">

Instructions

Inspector
Request attributes
2
Protocol
HTTP/1
HTTP/2
Name
Value
Method
GET
Path
/vulnerabilities/csrf/
Request cookies
2
Request headers
16
Name
Value
Host
127.0.0.1:42001
sec-ch-ua
"Chromium";v="151",...
sec-ch-ua-mobile
?0
sec-ch-ua-platform
"Linux"
Accept-Language
en-US,en;q=0.9
Upgrade-Insecure-Re...
1
User-Agent
Mozilla/5.0 (X11; Linu...
Accept
text/html,application/...
Sec-Fetch-Site
same-origin
Sec-Fetch-Mode
navigate
Sec-Fetch-User
?1
Sec-Fetch-Dest
document
Referer
http://127.0.0.1:4200...
Accept-Encoding
gzip, deflate, br
Cookie
PHPSESSID=8227bb...
Connection
keep-alive
Response headers
8
Search
0 highlights



RESULT:

The DVWA CSRF password-change form was accessed at Low security and its HTTP request was inspected using Burp Suite. The captured form and request show no user_token parameter. The provided evidence includes an HTTP 200 OK response; however, a successful password change was not conclusively demonstrated by the supplied screenshots. The final result should be marked successful only after verifying the change with DVWA's Test Credentials control.